

TITLE:
**From Vulnerability to Compliance: Securing Legacy
Systems at Apex Healthcare Solutions**

Written by: Aisha Duze

Client name:	Apex Healthcare Solutions
Assessment period:	July 2026

EXECUTIVE SUMMARY

Group225 Limited have concluded the security review of the legacy systems Kioptrix 1 and Metasploitable 2 which Apex Healthcare Solutions hold within their environment. Following extensive testing and analysis, 6 key vulnerabilities were uncovered and their implications, risk assessments and policy recommendations are presented within this summary.

KEY FINDINGS:

Found within this section are highlights of our findings and their implications for the Business.

High Risk Vulnerabilities:

The table below contains the vulnerabilities that were uncovered and they are ranked based on their severity, i.e. the level of impact they will have on the business if exploited.

S/N	VULNERABILITY	IMPACT	SEVERITY	AFFECTED SYSTEM
1	VSFTPD 2.3.4 Backdoor (CVE-2011-2523)	An unauthorized user or bad actor has access to take over the server, steal information, alter data, install malicious software and attack other systems within Apex's environment. This means potential service disruptions, data leaks and financial losses due to fines or penalties.	CRITICAL	Metasploitable 2
2	Java RMI Registry Remote Code Execution	This vulnerability allows an attacker take over the server or entire system, running malicious code remotely. This will lead to service disruptions and data breaches followed by financial losses due to fines.	CRITICAL	Metasploitable 2
3	Samba Trans2Open Remote Code Execution	An attacker can take administrative control of the server, with the ability to view, alter and delete sensitive data. This will result in service disruptions as well.	CRITICAL	Kioptrix 1
4	Debian OpenSSL/OpenSSH RNG Weakness (CVE-2008-0166)	This means that encryption is weak, and so it's easy for unauthorized users to gain access to internal systems and confidential information. Business implications include data leaks, reputational damage and financial losses due to fines.	HIGH	Metasploitable 2

Security Control Recommendations:

Vulnerability	Affected System	Recommended Security Control	How the Control Reduces Risk
VSFTPD 2.3.4 Backdoor (CVE-2011-2523)	Metasploitable 2	Patch Management Process	This control ensures that the backdoored/compromised software is identified, updated and/or removed before it can be exploited. Regular patching reduces exposure to publicly known vulnerabilities.
Debian OpenSSL/OpenSSH RNG Weakness (CVE-2008-0166)	Metasploitable 2	Cryptographic Key Management	After updating OpenSSL under this control, all SSH keys and digital certificates generated with a vulnerable library will be revoked and regenerated to restore cryptographic trust and prevent unauthorized access.
Java RMI Registry Remote Code Execution	Metasploitable 2	Secure Service Configuration and Network Segmentation	This control restricts unnecessary Java RMI services, limits access using firewalls, and exposes the service to trusted hosts only. It reduces the likelihood of remote code execution by preventing unauthorized access to the RMI registry.
Samba Trans2Open Remote Code Execution	Kioptrix 1	Vulnerability and Patch Management	This control updates Samba to a supported version, removing the remote code execution vulnerability and preventing attackers from obtaining unauthorized root access.

Policy Recommendations:

1. Patch Management Policy

Implementing a patch management policy ensures that operating systems, applications, and network services are regularly updated to address known security vulnerabilities. During the vulnerability assessment process, both Metasploitable 2 and Kioptrix 1 were found to contain outdated software that allow attackers gain control remotely. Apex Healthcare Solutions will greatly reduce the likelihood of successful attacks against known vulnerabilities when patching responsibilities, testing procedures, and remediation timelines are clearly defined within this policy.

2. Vulnerability Management Policy

This policy establishes a structured process for performing vulnerability assessments, result analysis, prioritizing remediation by risk, and validating the completed remediation. Our activities identified several critical and medium-risk vulnerabilities, demonstrating the need for continuous vulnerability management rather than periodic, one-time assessments. This policy enables a proactive approach to risk reduction and continual improvement.

3. Secure Configuration and System Hardening Policy

A secure configuration policy requires systems to be deployed using approved baseline configurations and hardened in line with recognized security standards. Our findings such as SSLv2/SSLv3 support and exposed Java RMI services are examples of how insecure default configurations increase vulnerability. Implementing this policy will ensure that only necessary services and protocols are in use, and Apex's overall system security is strengthened.

4. Cryptographic Key Management Policy

This policy sees to the secure generation, storage, rotation, revocation, and replacement of cryptographic keys and certificates. It specifically addresses the OpenSSL random number generator weakness which we identified during our assessment. A formal, structured key management process ensures that compromised keys are replaced promptly and that encryption remains effective in protecting sensitive healthcare data.

Overall Security Posture:

Apex Healthcare Solutions currently has a moderate to high risk security posture. While no active compromise was found to be in effect, the legacy systems Metasploitable 2 and Kioptrix 1 contain weaknesses that pose significant threats to the confidentiality, integrity and availability of the data held within the environment. Immediate remediation is advised to prevent unauthorized access, data compromise, service disruptions, reputational damage to the business and ultimately, potentially huge financial losses.

VULNERABILITY ASSESSMENT REPORT

Background:

Apex Healthcare Solutions is a medium-sized healthcare technology company that provides digital patient record services to clinics and hospitals. As part of its commitment to protecting sensitive patient information and maintaining secure operations, the organization commissioned a cybersecurity assessment of two legacy systems identified within its environment, namely Kioptrix and Metasploitable 2.

The objective of this assessment was to identify vulnerabilities present within the systems, evaluate the potential risks associated with those vulnerabilities, and recommend appropriate security controls and governance measures to mitigate identified threats. The assessment focused on understanding the business impact of the vulnerabilities and their implications for the confidentiality, integrity, and availability of critical healthcare data.

The security assessment involved reconnaissance, service enumeration, vulnerability identification, and risk evaluation using industry-standard tools such as Netdiscover, Nmap, and Nessus Essentials. The review was conducted from both technical and governance perspectives to provide management with practical recommendations for improving the organization's security posture.

Given the sensitive nature of healthcare information, weaknesses within the identified systems could expose Apex Healthcare Solutions to unauthorized access, data breaches, service disruptions, regulatory non-compliance, and reputational damage. Consequently, this report presents the vulnerabilities identified, their associated risks, and the recommended security controls and policies required to strengthen the security of the organization's information systems.

The security assessment was performed by Group225 Limited between 1st July and 18 July 2026.

Objectives:

Based on the scope of work, the objectives of the assessment are as follow:

- Identify the vulnerabilities discovered in the systems
- Explain the security impact of the vulnerabilities
- Assess the business risk
- Recommend security controls
- Recommend organizational policies
- Present findings in a professional report

Vulnerability Identification:

The following table contains details of the most critical vulnerabilities the team's assessments of Metasploitable 2 and Kioptrix 1 respectively.

Vulnerability Name	Affected Service	Brief Description	Potential Attacker Goal
VSFTPD 2.3.4 Backdoor (CVE-2011-2523)	FTP Service (Port 21)	This is a malicious backdoor that is found in VSFTPD version 2.3.4 that allows attackers to execute commands remotely and obtain root-level access without authentication.	The attacker aims to gain complete control of the server, steal sensitive information, install malware, or use the compromised system to attack other network resources.

Debian OpenSSL/OpenSSSH Service (Port H RNG Weakness 22) (CVE-2008-0166)		This is a flaw in Debian's implementation of OpenSSL whereby the generated cryptographic keys are predictable, which significantly weakens SSH authentication and compromises encrypted communications.	An attacker will most likely aim to impersonate legitimate users, gain unauthorized access to systems, or compromise sensitive information protected by weak cryptographic keys.
Java RMI Registry Remote Code Execution	Java RMI Registry Service (Port 1099)	The default configuration of Java RMI Registry permits remote class loading, potentially allowing attackers to execute malicious code on the affected server.	The attacker's goal is to remotely execute malicious code, gain unauthorized access to the server, and disrupt or tamper with critical services.
Samba Trans2Open Remote Code Execution	Samba/SMB File Sharing Services (Ports 139 and 445)	A vulnerability in Samba's Trans2Open function allows attackers to remotely execute code and obtain administrative privileges on affected systems.	An attacker will gain root-level access to the server, modify or delete sensitive information, and compromise the availability of organizational services.
SSL Version 2 & 3 Protocol Detection	HTTPS/SSL Secure Communications Service	The affected system supports obsolete SSL protocols that are vulnerable to well-known cryptographic attacks and no longer provide adequate protection for sensitive information.	In this instance, an attacker's goal will be to intercept or decrypt sensitive information transmitted across the network or exploit weaknesses in legacy encryption protocols.
SMB Signing Not Required	SMB File Sharing Service (Port 445)	The SMB service does not require message signing, making it possible for attackers on the same network to intercept or modify communications between systems.	An attacker intends to perform man- in-the-middle attacks, manipulate file- sharing communications, or capture sensitive information exchanged between trusted systems.

Risk Assessment:

The team carried out a qualitative risk assessment where the likelihood of a successful exploitation of the vulnerability is combined with its potential impact to determine the risk rating. The result is the table below:

Vulnerability	Likelihood	Impact	Risk Rating	Explanation
VSFTPD 2.3.4 Backdoor (CVE-2011-2523)	High	High	High	This is a well-know, publicly documented vulnerability. We successfully exploited it during our assessment and gained root access. Attackers can replicate this very easily and the combination of this ease of exploitation with complete system compromise result in a high risk rating.
Debian OpenSSL/OpenSS H RNG Weakness (CVE-2008-0166)	Medium	High	High	This vulnerability requires an extra step of obtaining the weak cyptographic keys, making it a little more complicated that remote code execution. However it does have a high impact

				because it results in unauthorized access to and control of sensitive information. It is thus rated high because the resulting authentication compromises poses a great security risk to the business.
Java RMI Registry Remote Code Execution	High	High	High	This is another publicly known vulnerability for remote code execution. It also enables attackers gain complete control of the target systems. This is of course a high impact, high likelihood and therefore high risk situation that warrants immediate remediation.
Samba Trans2Open Remote Code Execution	High	High	High	The team successfully exploited this vulnerability without the need for authentication and gained root access. This is a high likelihood, high impact vulnerability because attackers can quickly take over systems and access sensitive information. It is thus rated high risk.
SSL Version 2 & 3 Protocol Detection	Medium	Medium	Medium	This is a medium-risk vulnerability because the attacker will need to first intercept the network before exploiting it. The impact also depends on the sensitivity of the information found within the network. This combination of medium likelihood and medium impact give it a medium-risk rating.
SMB Signing Not Required	Medium	Medium	Medium	This is also a medium-risk vulnerability. This is because the attacker has to be within the targeted network segment in order to intercept communications. The impact is medium because the possibility of data tampering or interception of communications is not guaranteed. This results in a medium risk rating.

Security Control Recommendations:

To address these vulnerabilities, the team recommends the following security control measures:

Vulnerability	Affected System/Service	Recommended Security Control	How the Control Reduces Risk
VSFTPD 2.3.4 Backdoor (CVE-2011-2523)	Metasploitable 2/FTP (Port 21)	Patch Management Process	This control ensures that the backdoored/compromised software is identified, updated and/or removed before it can be exploited. Regular patching reduces exposure to publicly known vulnerabilities.
Debian OpenSSL/OpenSSH RNG Weakness (CVE-2008-0166)	Metasploitable 2/SSH Service (Port 22)	Cryptographic Key Management	After updating OpenSSL under this control, all SSH keys and digital certificates generated with a vulnerable library will be revoked and regenerated to restore cryptographic trust and prevent unauthorized access.
Java RMI	Metasploitable	Secure Service	This control restricts unnecessary Java RMI

Registry Remote Code Execution	2/Java RMI (Port 1099)	Configuration and Network Segmentation	services, limits access using firewalls, and exposes the service to only trusted machines. It reduces the likelihood of remote code execution by preventing unauthorized access to the RMI registry.
Samba Trans2Open Remote Code Execution	Kioptrix 1/Samba File Sharing(port 139 and 445)	Vulnerability and Patch Management	This control updates Samba to a supported version, removing the remote code execution vulnerability and preventing attackers from obtaining unauthorized root access.
SSL Version 2 & 3 Protocol Detection	Kioptrix 1/SSL/TLS Services (targeting encrypted communication)	Secure Baseline Configuration	This control reduces risk by disabling deprecated(obsolete) SSL protocols and enforcing the use of the more secure TLS 1.2 or TLS 1.3 to protect encrypted communications against known cryptographic attacks.
SMB Signing Not Required	Kioptrix 1/SMB File Sharing Service (Port 445)	Secure Network Configuration	Under this control, SMB signing is configured to be required on both clients and servers, which ensures message integrity and reducing the risk of man-in-the-middle attacks.

Governance, Risk, And Compliance (GRC) Policy Recommendations:

Following the vulnerability and risk assessments carried out, we recommend that Apex Healthcare Solutions should implement the following governance policies to strengthen its cybersecurity posture and reduce organizational risk.

Policy	Purpose	Why Apex Healthcare Solutions Needs It	Vulnerabilities Mitigated
Patch Management Policy (NIST CSF 2.0, ISO 27001, CIS Controls v8)	To establish procedures for identifying, testing, approving, deploying, and verifying security patches within defined time frames.	The assessment revealed multiple outdated and vulnerable services that exposed critical systems to remote code execution. A formal patch management process reduces the likelihood of known vulnerabilities remaining exploitable.	VSFTPD 2.3.4 Backdoor, Samba Trans2Open, Debian OpenSSL RNG Weakness
Vulnerability Management Policy (NIST CSF 2.0, CIS Controls v8)	This policy is implemented to define how vulnerabilities are continuously identified, assessed, prioritized, remediated, and monitored through regular vulnerability scanning and risk assessments.	Nessus identified numerous vulnerabilities across both systems, demonstrating the need for an ongoing process to discover and remediate weaknesses before they are exploited.	All identified vulnerabilities, including OpenSSL RNG Weakness, SSLv2/SSLv3, SMB Signing Not Required, Java RMI Registry RCE
Secure Configuration and System	Establishes the baseline secure configurations for operating systems,	Several of the team's findings resulted from insecure configurations. Standardized hardening reduces the organization's	SSL Version 2 & 3 Enabled, SMB Signing Not

Hardening Policy (CIS Controls v8, NIST CSF 2.0, ISO 27001)	network services, cryptographic protocols, and application servers before deployment into production.	attack surface.	Required, Java RMI Registry Remote Code Execution
Cryptographic Key Management Policy NIST SP 800-57, NIST CSF 2.0, ISO 27001	Defines requirements for generating, storing, rotating, revoking, and replacing cryptographic keys and digital certificates throughout their lifecycle.	The OpenSSL random number generator weakness demonstrated that compromised cryptographic keys can undermine authentication and encrypted communications. Proper key lifecycle management helps maintain the confidentiality and integrity of healthcare information.	Debian OpenSSL/OpenSSH RNG Weakness (CVE-2008-0166)

CONCLUSION

The assessment of GROUP 225 on Apex Healthcare Solutions' legacy systems has made one thing clear: Kioptrix 1 and Metasploitable 2 are carrying real, exploitable weaknesses that put the organization at meaningful risk. Six vulnerabilities were identified in total, and four of them, the VSFTPD 2.3.4 backdoor, the Java RMI Registry flaw, the Samba Trans2Open issue, and the Debian OpenSSL/OpenSSH RNG weakness, were rated critical or high severity. These weren't just theoretical findings, the team was able to actually exploit 2 of them during testing, i.e VSFTPD Backdoor 2.3.4 and Samba Trans2open in Metasploitable 2 and Kioptrix 1 respectively, which confirms just how easily a real attacker could do the same.

The good news is that no active compromise was detected in the environment during the assessment window. That said, given the sensitivity of the patient data Apex handles, these vulnerabilities still leave the door open to unauthorized access, data breaches, downtime, and potential regulatory trouble if left unaddressed. The two medium-risk findings, outdated SSL protocol support and the lack of SMB signing, add to this by leaving data in transit less protected than it should be.

To deal with this, the report lays out specific controls for each vulnerability, things like proper patch management, better handling of cryptographic keys, tighter service configuration and network segmentation, and stronger baseline hardening. But fixing today's vulnerabilities isn't enough on its own. That's why the report also recommends four governance policies covering patch management, vulnerability management, secure configuration, and cryptographic key management, so that Apex Healthcare Solutions isn't just reacting to problems as they come up, but actually building a process to catch and fix them going forward. These recommendations are grounded in established frameworks like NIST CSF 2.0, ISO 27001, and CIS Controls v8, giving Apex a solid foundation to build on.

Given everything found during this assessment, Group 225's recommendation is straightforward: address the critical and high-risk vulnerabilities as soon as possible, and follow through on adopting the governance policies outlined above. Doing both will go a long way toward protecting the confidentiality, integrity, and availability of Apex's systems and the patient data within them, and just as importantly, it moves the organization toward a more proactive, sustainable approach to security rather than one built around one-off fixes.